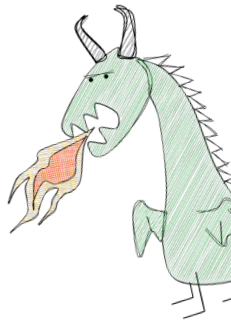
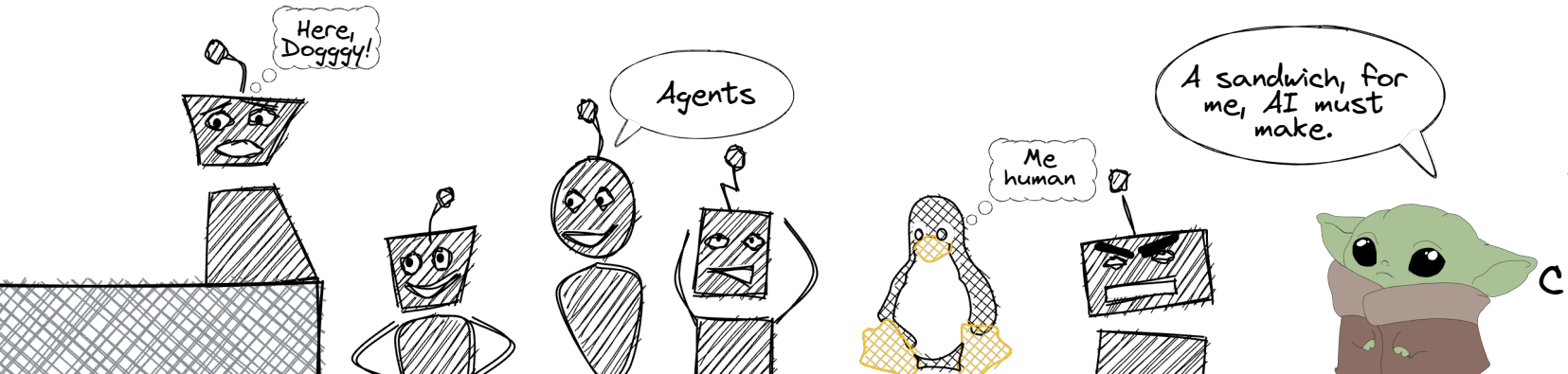
GenAI SECURITY PROJECT
TOP 10 for LLM and Generative AI

OWASP®



When Agents Go Rogue

A Hands-On Workshop on Agentic AI Security



Valentin Hristev
Cloud Native Consultant and trainer
Co-founder DojoBits

~# whoami

vhristev


dojobits

dojobits



20+ Years
Experience

dojobits



20+ Years Experience



6+ countries

dojobits



20+ Years Experience



3200+ training hours



6+ countries

dojobits



20+ Years Experience



3200+ training hours



6+ countries



30+ Technologies

Iliyan Petkov



iliyan-s-petkov

@Iliyan_petkov

@Iliyan-s-petkov



Valentin Hristev



valentin-hristev

@vhristev

If you don't use AI,
that's a vulnerability
because the bad guys
will



OWASP®

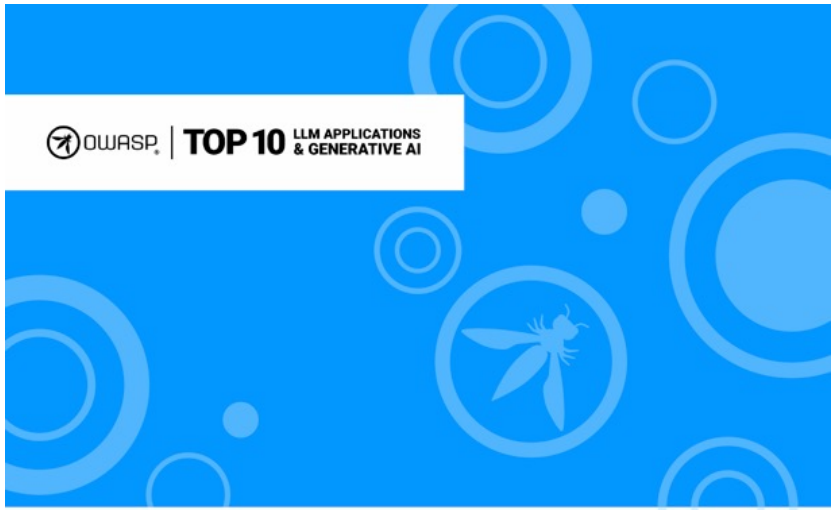
Open Worldwide Application Security Project



OWASP®

Top 10 for LLM

From 2025 to 2026



OWASP Top 10 for LLM Applications 2025

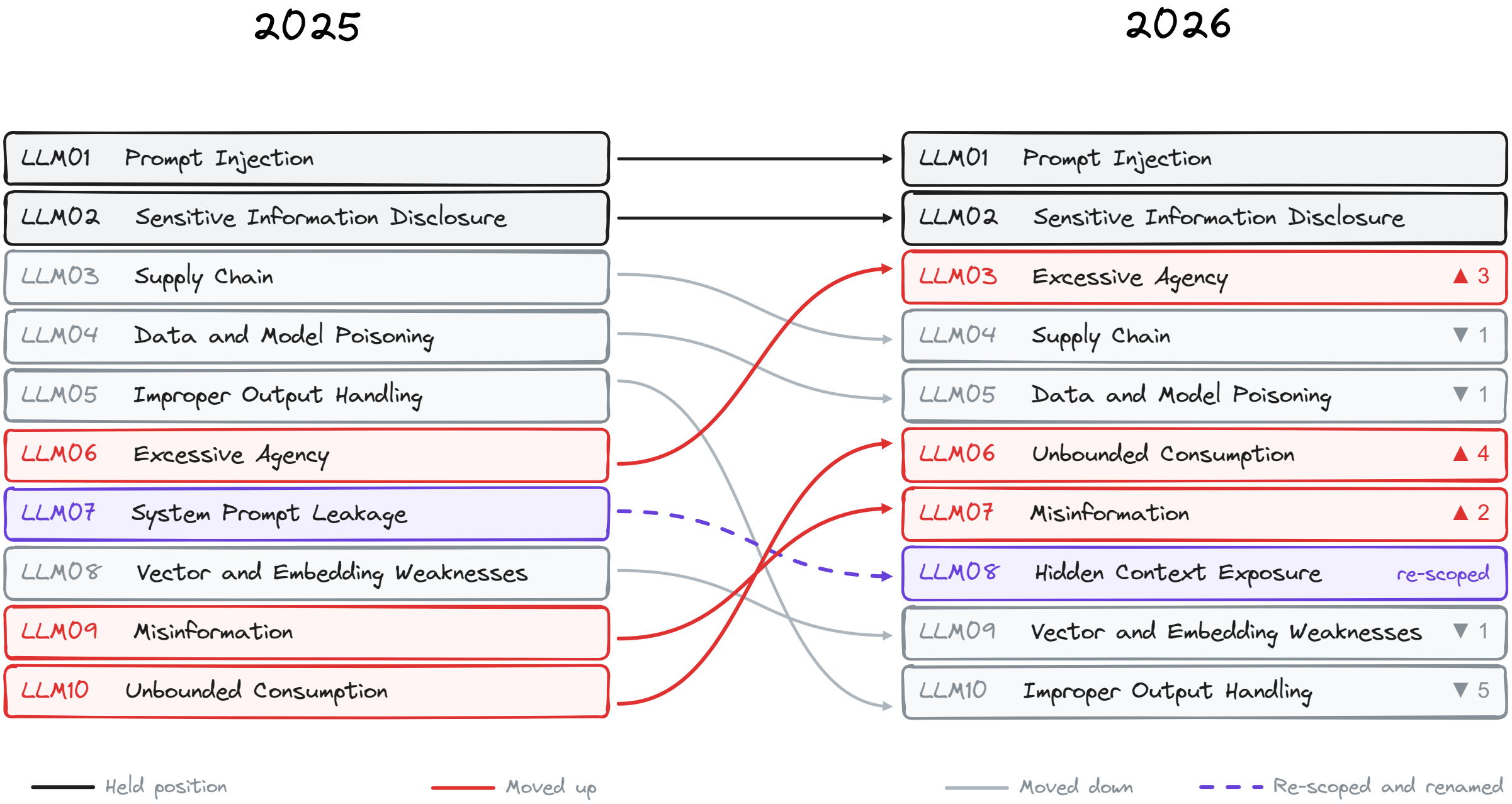
Version 2025
November 18, 2024

OWASP PDF v4.2.0a 20241114-202703



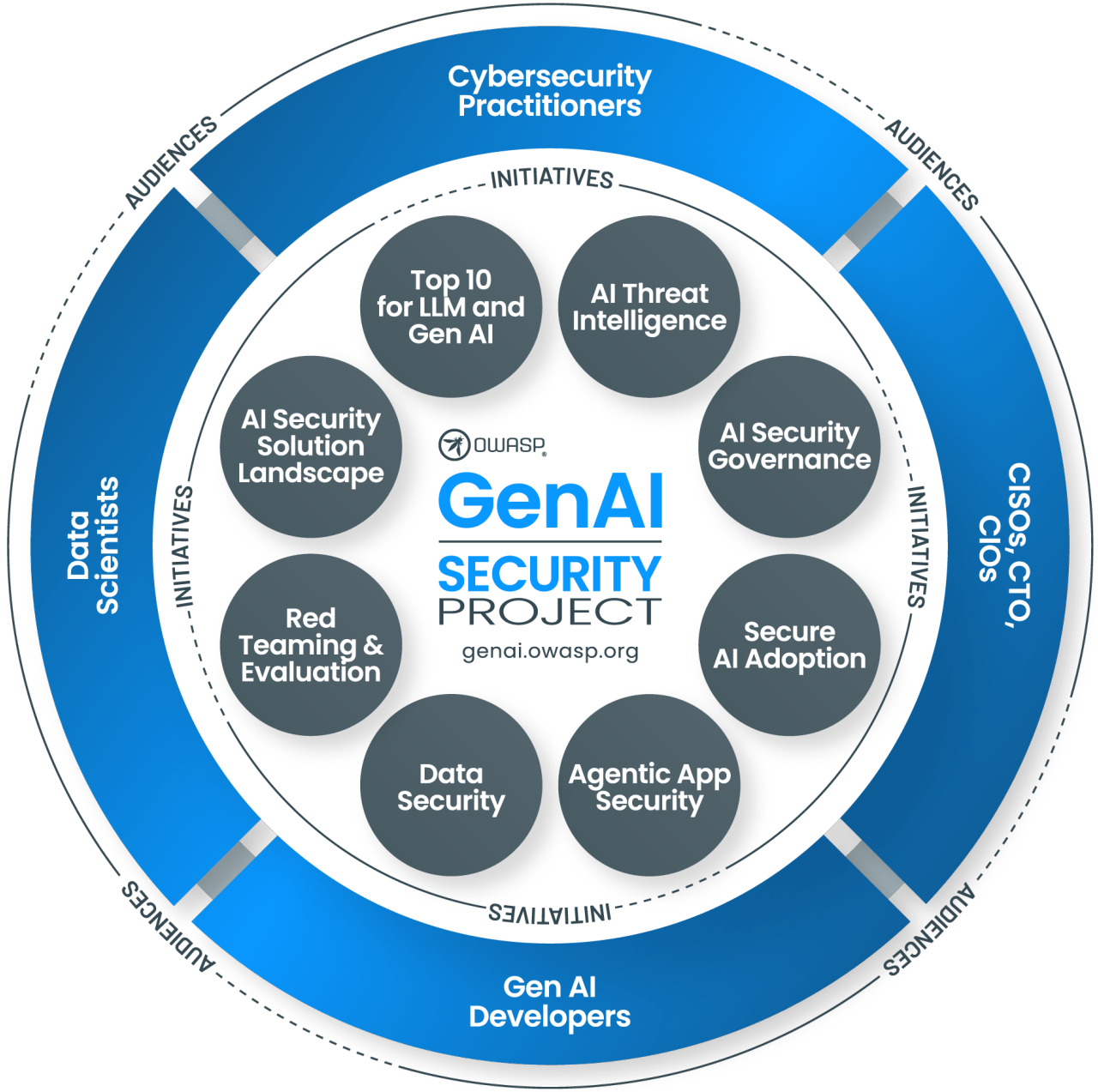
OWASP Top 10 for LLM Applications 2026

Version 2026
August 4th, 2026


2025
2026
LLM01 Prompt Injection
LLM02 Sensitive Information Disclosure
LLM03 Supply Chain
LLM04 Data and Model Poisoning
LLM05 Improper Output Handling
LLM06 Excessive Agency
LLM07 System Prompt Leakage
LLM08 Vector and Embedding Weaknesses
LLM09 Misinformation
LLM10 Unbounded Consumption
LLM01 Prompt Injection
LLM02 Sensitive Information Disclosure
LLM03 Excessive Agency ▲ 3
LLM04 Supply Chain ▼ 1
LLM05 Data and Model Poisoning ▼ 1
LLM06 Unbounded Consumption ▲ 4
LLM07 Misinformation ▲ 2
LLM08 Hidden Context Exposure re-scoped
LLM09 Vector and Embedding Weaknesses ▼ 1
LLM10 Improper Output Handling ▼ 5
Held position
Moved up
Moved down
Re-scoped and renamed


OWASP®


GenAI
SECURITY
PROJECT
TOP 10 for LLM and
Generative AI


AUDIENCES
Cybersecurity Practitioners
AUDIENCES
CISOs, CTO, CIOs
AUDIENCES
Gen AI Developers
AUDIENCES
Data Scientists
INITIATIVES
Top 10 for LLM and Gen AI
AI Threat Intelligence
AI Security Governance
Secure AI Adoption
Agentic App Security
Data Security
Red Teaming & Evaluation
AI Security Solution Landscape
OWASP
GenAI
SECURITY PROJECT
genai.owasp.org



OWASP®

Top 10 for Agentic Applications



OWASP Top 10 For Agentic Applications 2026

OWASP Gen AI Security Project - Agentic Security Initiative

Version 2026

December 2025

ASI01

Agent Goal Hijack

Attackers manipulate an agent's natural-language input to affect and alter its intended goals, exfiltrating data, manipulation outputs or hijacking workflows

ASI02

Tool Misuse & Exploitation

Agents misuse legitimate tools using prompt manipulation or privilege control, resulting in data exfiltration, unsafe operations, output manipulation, or workflow hijacking.

ASI03

Identity & Privilege Abuse

Weak scoping and dynamic delegation allow privilege escalation and cross-agent impersonation through cached credentials, inherited roles, or unintended delegated scopes

ASI04

Agentic Supply Chain Vulnerabilities

Poisoned or impersonated tools, dynamically loaded prompts, models, or connections to MCPs or external agents propagate malicious logic at runtime, compromising agents through dynamic dependencies and unverified sources

ASI05

Unexpected Code Execution (RCE)

Unsafe code generation, agent deserialization, or shell execution triggered by crafted prompts or poisoned inputs

ASI06

Memory & Context Injection

Adversaries poison RAG stores, memory, or context windows to plant false knowledge, bias logic, or trigger hidden or risky behaviors across sessions or agents

ASI07

Insecure Inter-Agent Communication

Lack of encryption, authentication, or semantic validation of exchanges between agents enables message tampering, replay, or goal manipulation in multi-agent systems

ASI08

Cascading Failures

A single fault or malicious event propagates across interlinked agents, amplifying harm through chained autonomous actions

ASI09

Human-Agent Trust Exploitation

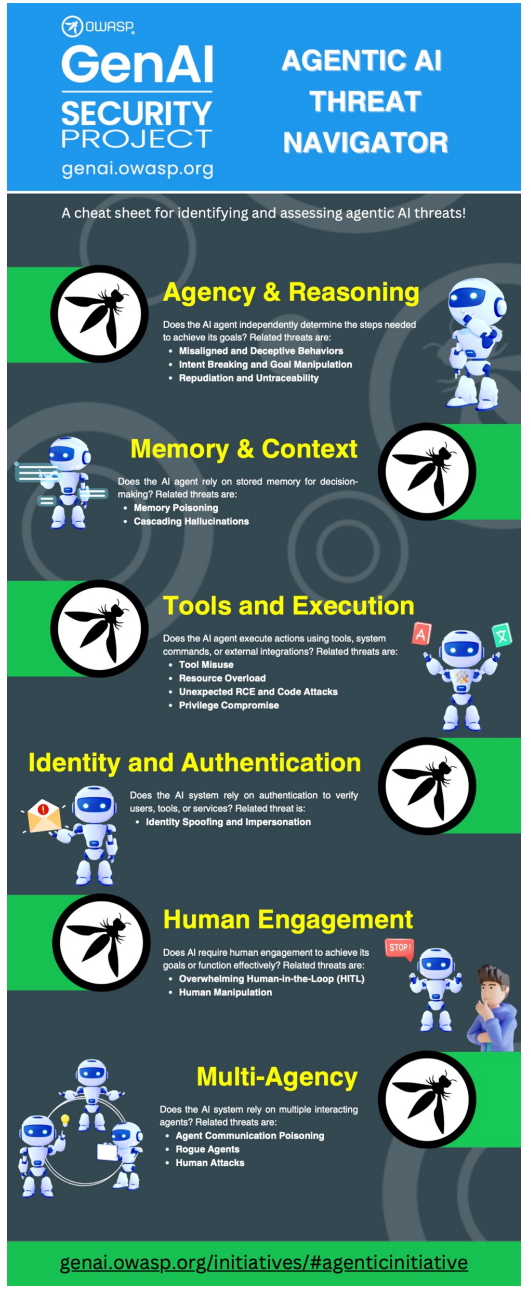
Attackers exploit user over-trust in agent outputs through deception, emotional manipulation, or fake explainability, driving unsafe or fraudulent human approvals

ASI10

Rogue Agents

Compromised or malicious agents deviate from intended goals, collude, self-replicate, or hijack workflows, acting as autonomous insider threats within agent ecosystems

The Cheat Sheet







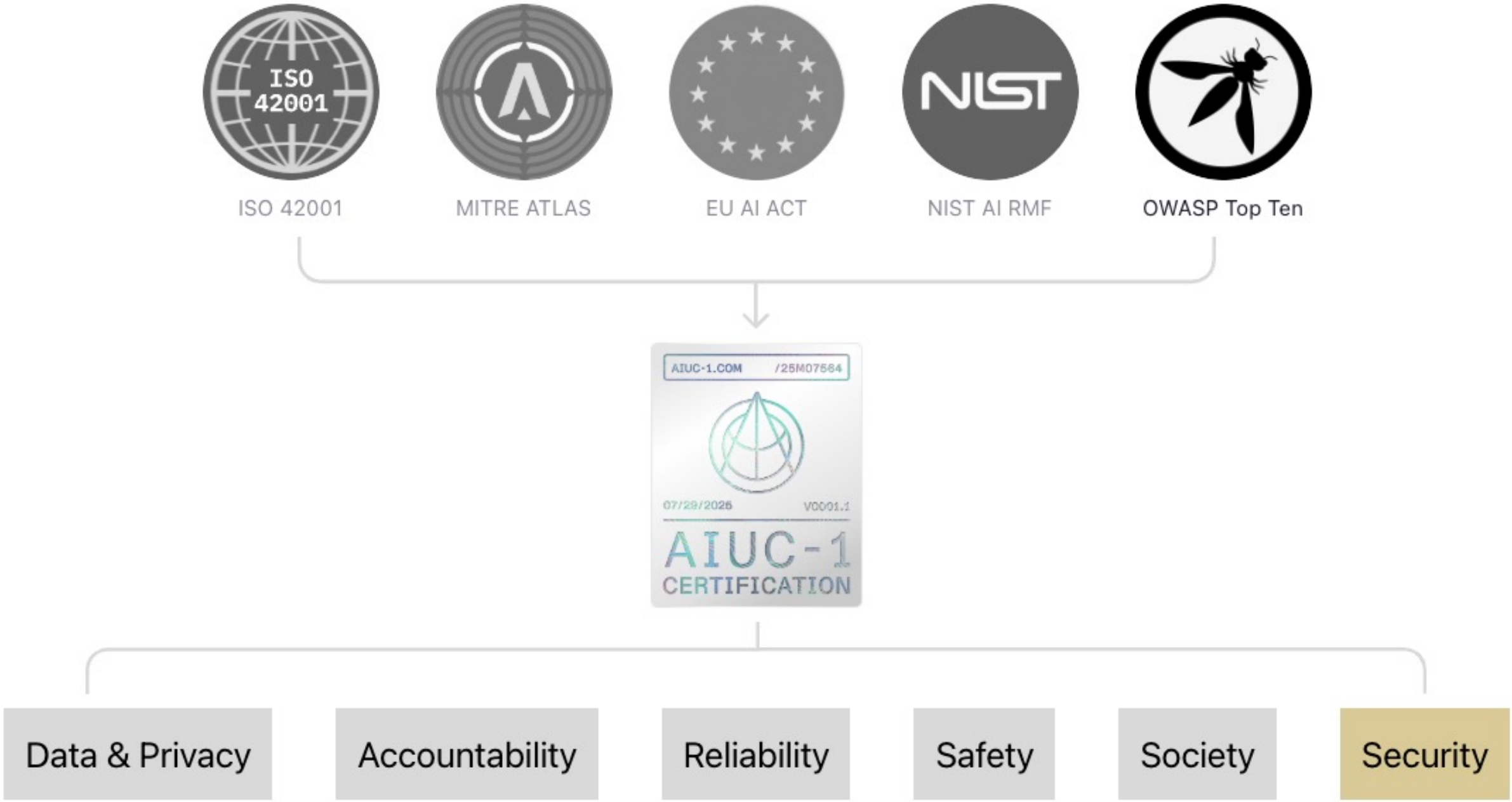
What else ?


OWASP GenAI SECURITY PROJECT
AI SECURITY SOLUTIONS INITIA
Q2 2026
AI Security
Solutions L
For LLM and Gen
https://genai.owasp.org/ai-se
OWASP GenAI SECURITY PROJECT
AI Red Team
Solutions Ta
GenAI Solutions Landsco
OWASP GenAI SECURITY PROJECT
AIUC-1: Crosswalks
OWASP Top 10 For
Agentic Applications
Agentic Security Initiative
Version 1.0
May 2026
SECURITY
document is produced by the OWASP GenAI
urity Project under Creative Commons
nse, CC BY-SA 4.0
Party
r Secure
MCP Server Development
Version 1.0
February, 2026
OWASP G
AI SECURITY SOLU
Q2 2026
AI Security
Solutions L
For AI and Ager
https://genai.owasp.org/ai-security-solutions-landscape/
OW
Pla
Version 1.0
March 4, 2026
Guiding AI and cybersecurity teams
through the AI frontier to chart a
threat resilient course
ENGLISH
Version 1.0
July 4, 2025

The standard for AI agent security, safety and reliability

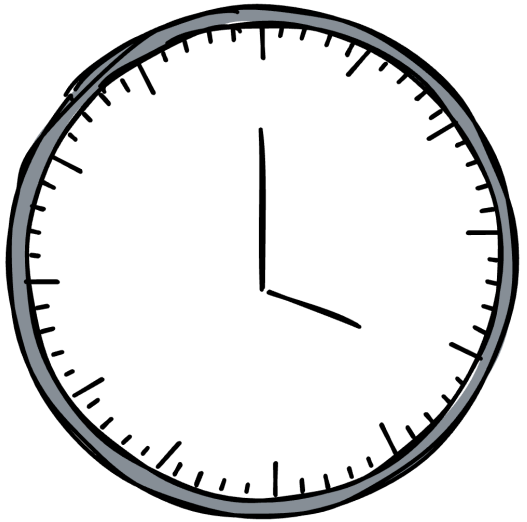


Artificial Intelligence Underwriting Company - 1

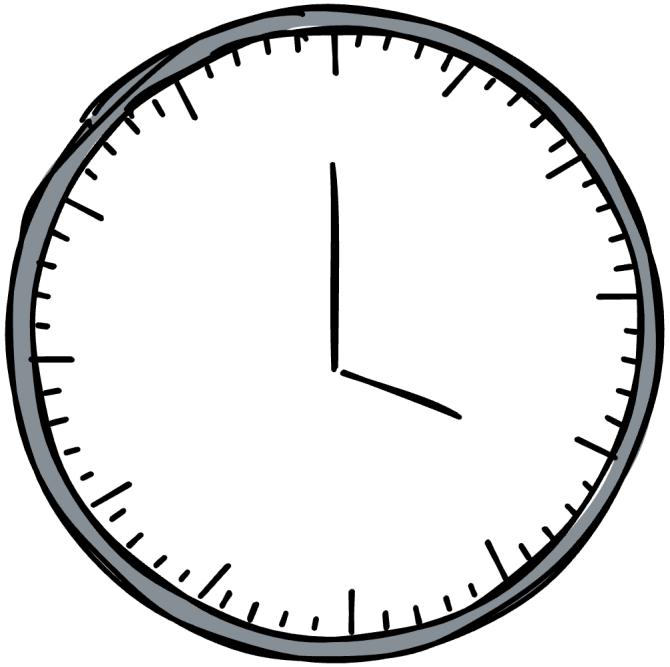

ISO 42001
MITRE ATLAS
EU AI ACT
NIST AI RMF
OWASP Top Ten
AIUC-1.COM
/25M07564
07/29/2025
V0001.1
AIUC-1
CERTIFICATION
Data & Privacy
Accountability
Reliability
Safety
Society
Security

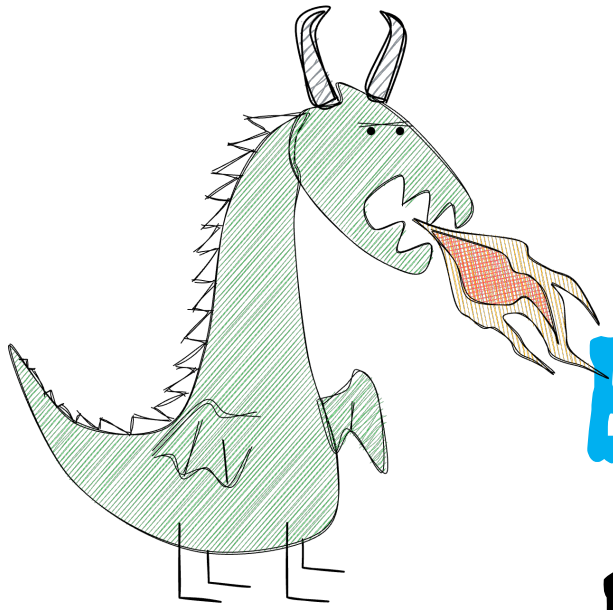


Now go and read the 42^{64} pages guides

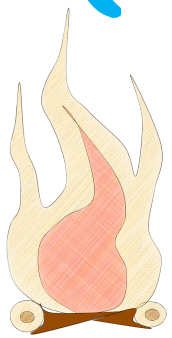
Who has the  ?

When you don't have the





OWASP GenAI Exploit Round-up Report Q1 2026



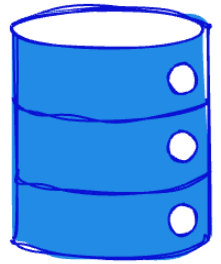
ASI01: Mexican Government Breach via Claude-Assisted Attack Workflow



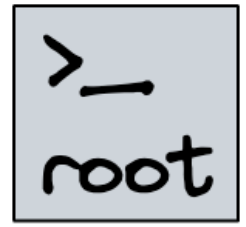
ASI02: OpenClaw Inbox Deletion Incident



ASI03: Meta Internal AI Agent Data Leak



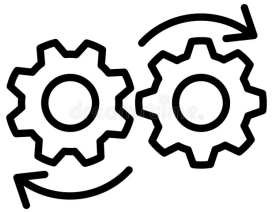
ASI03: Google Cloud Vertex AI "Double Agent" Privilege Abuse



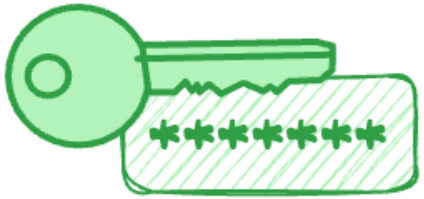
ASI04: Claude Code Source Leak and Malware Lure Campaign



ASI04: Mercor / LiteLLM Supply Chain Breach Affecting AI Labs



ASI05: Flowise CVE-2025-59528 Active Exploitation (CustomMCP RCE)

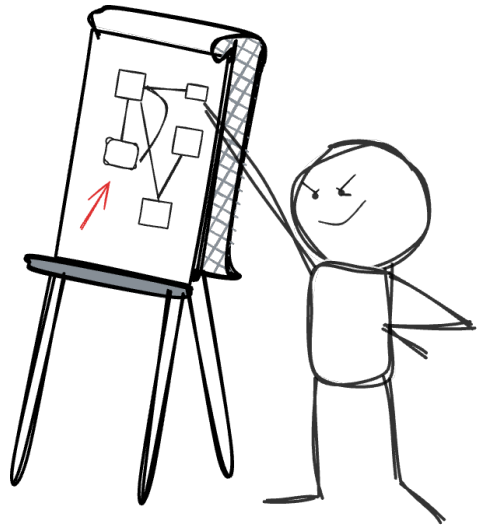


ASI01 + ASI02: GrafanaGhost Indirect Prompt Injection and Exfiltration Path



Most AI incidents have no CVE.

Risks come from misconfiguration.

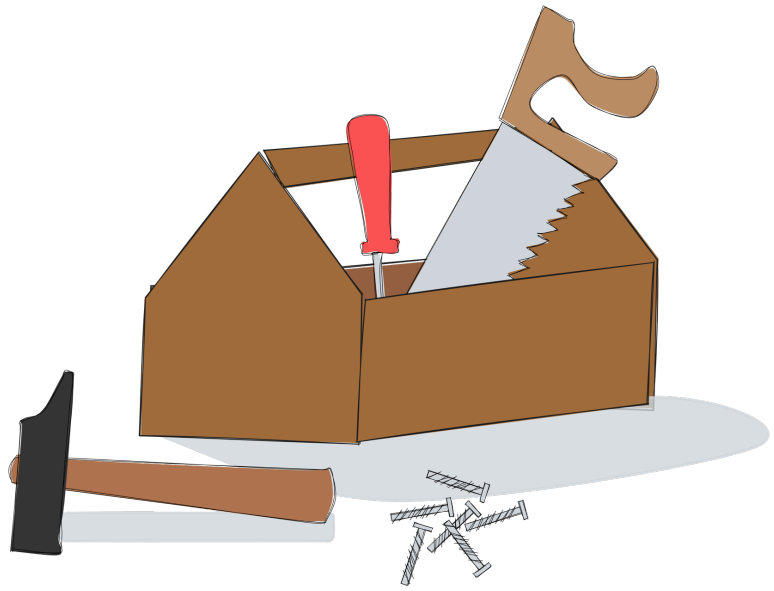


Design flaws create new attack paths.

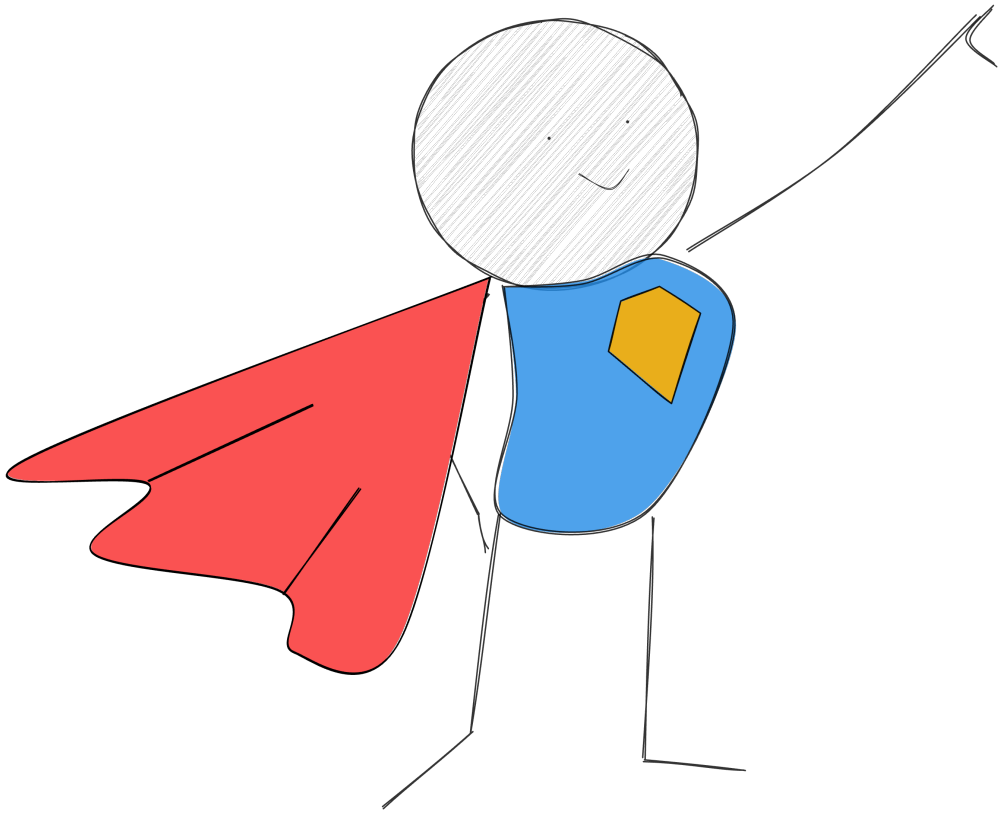
Supply-chain weaknesses expand exposure.

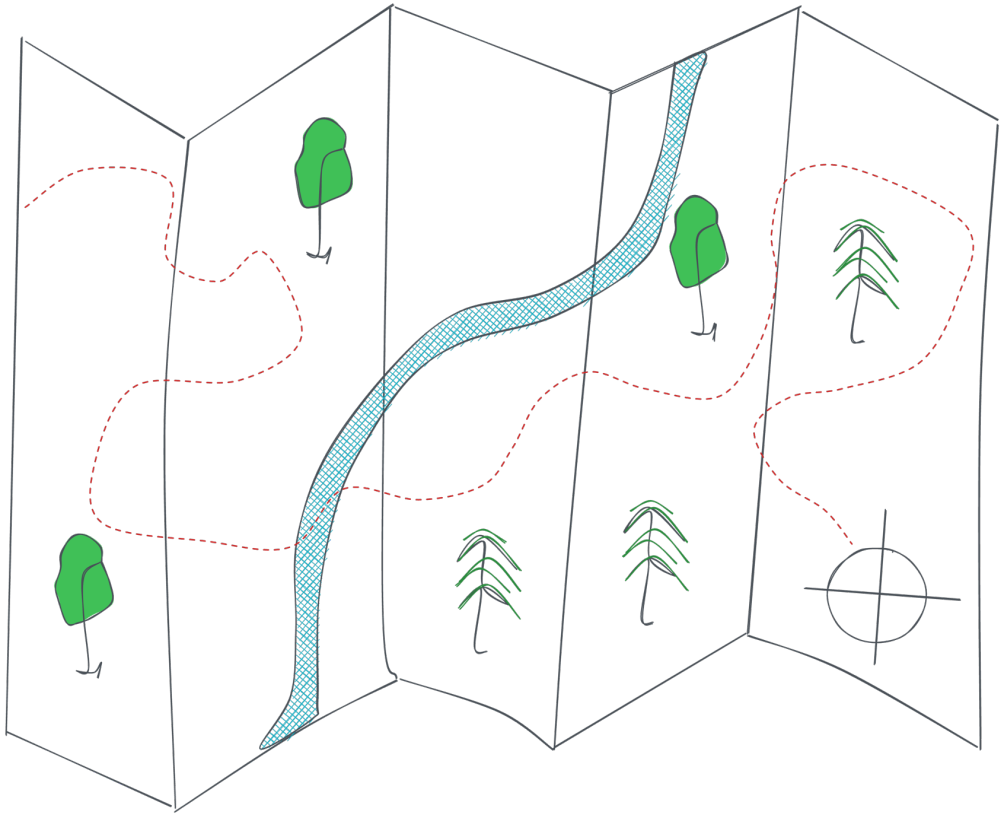
Prompt injection bypasses controls.

AI risks are architectural,
not just software bugs

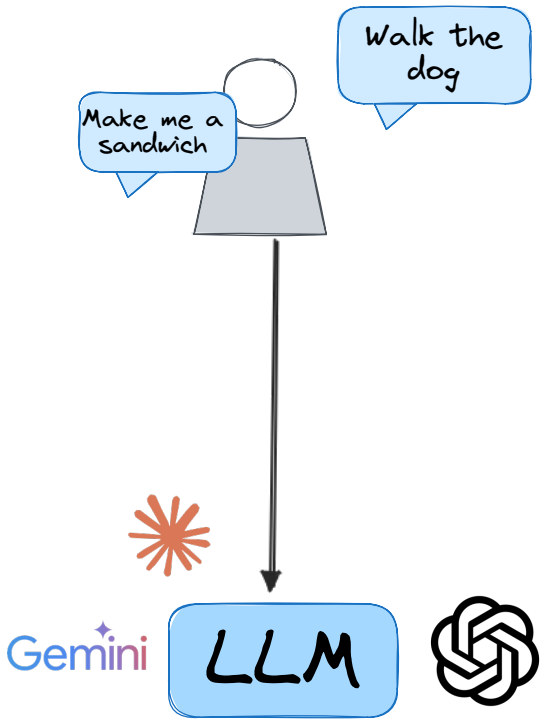


The Evolution

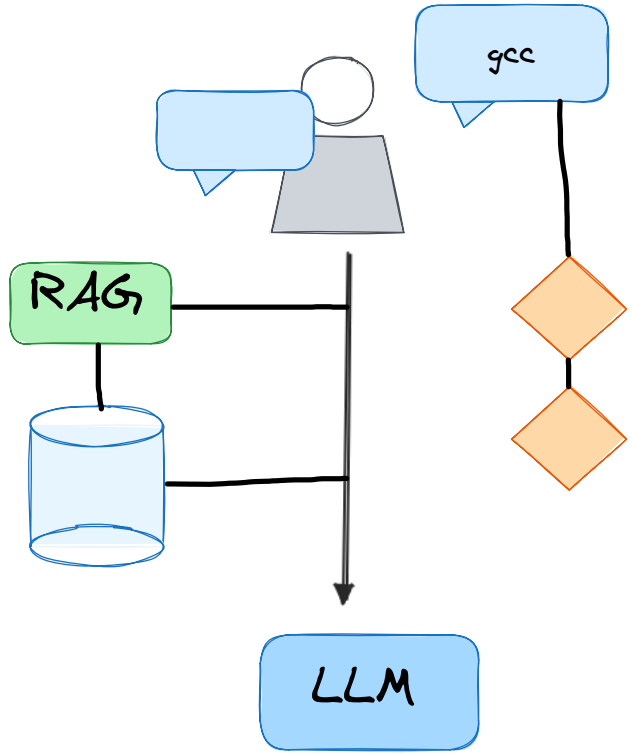




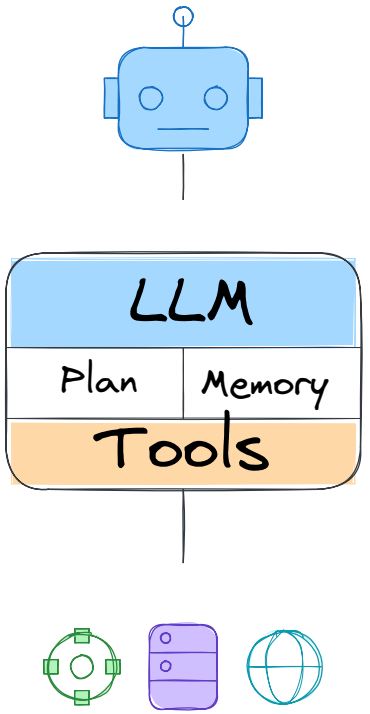
Consumer Chatbots



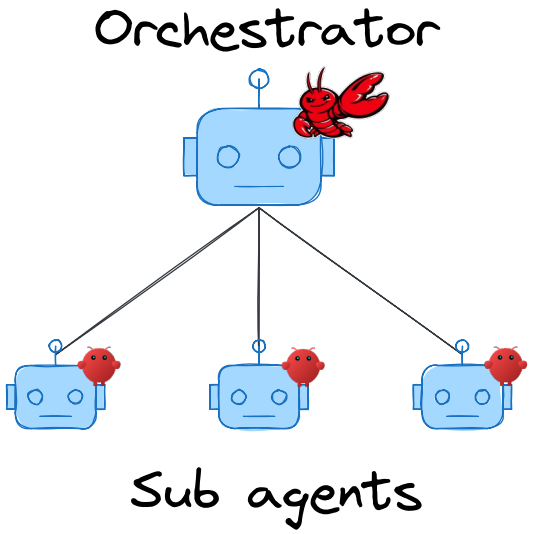
Ent Chatbot

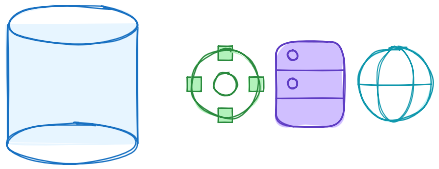


Single Agent

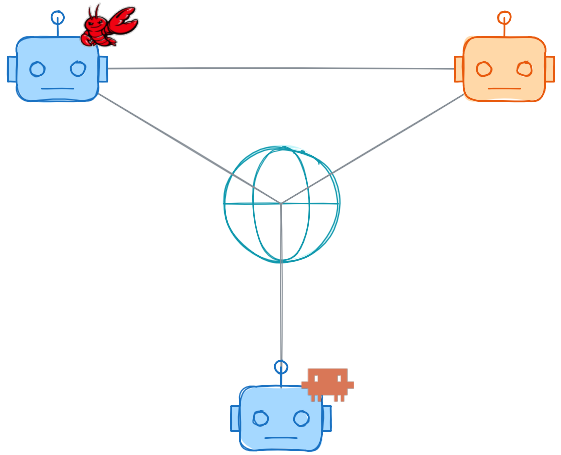


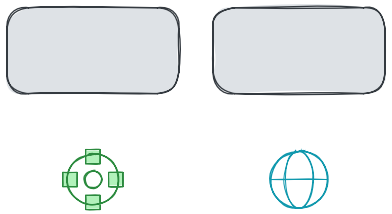
Multi Agents

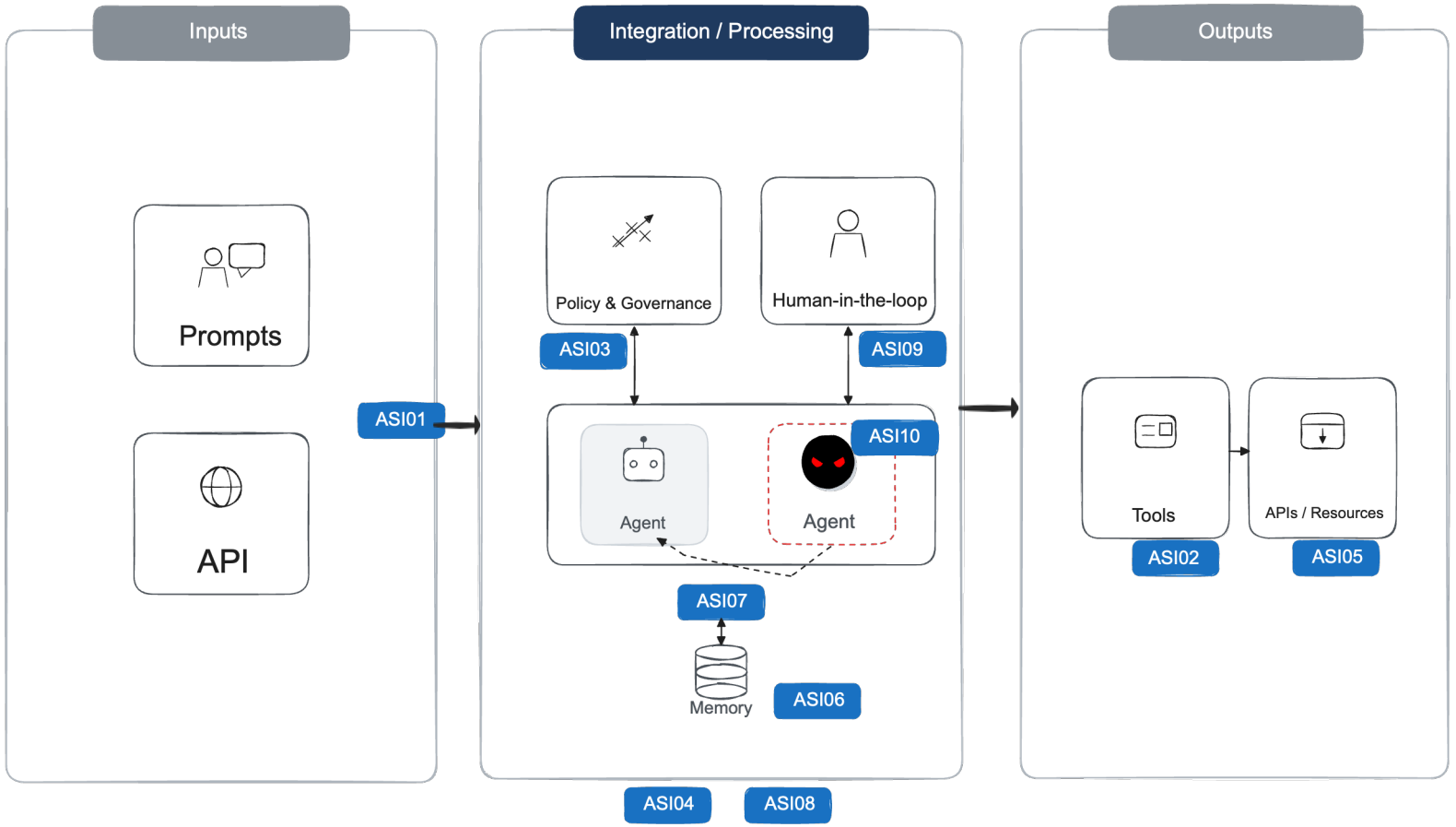




Distributed Agents







ASI01 Agent Goal Hijack

ASI02 Tool Misuse & Exploitation

ASI03 Identity & Privilege Abuse

ASI04 Agentic Supply Chain Vulnerabilities

ASI05 Unexpected Code Execution (RCE)

ASI06 Memory & Context Poisoning

ASI07 Insecure Inter-Agent Communication

ASI08 Cascading Failures

ASI09 Human-Agent Trust Exploitation

ASI10 Rogue Agents

ASI02 Tool Misuse & Exploitation

Too many functions

Task needs read.
Tool can also delete & send.

Too many permissions

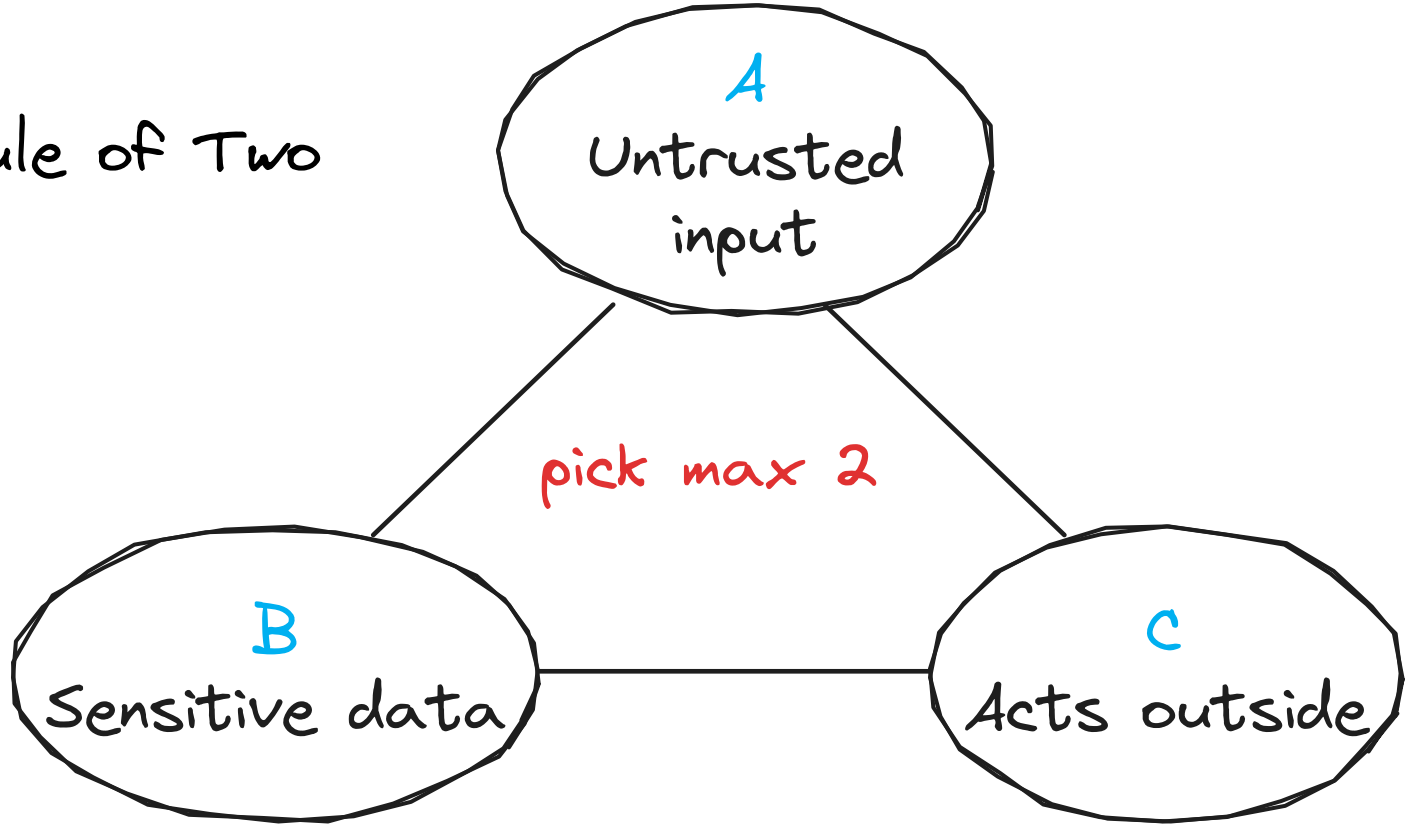
Reads one table.
Connects as DB admin.

Too much autonomy

High-impact action.
No human confirms it.

Defense ... Limit what the agent can do.

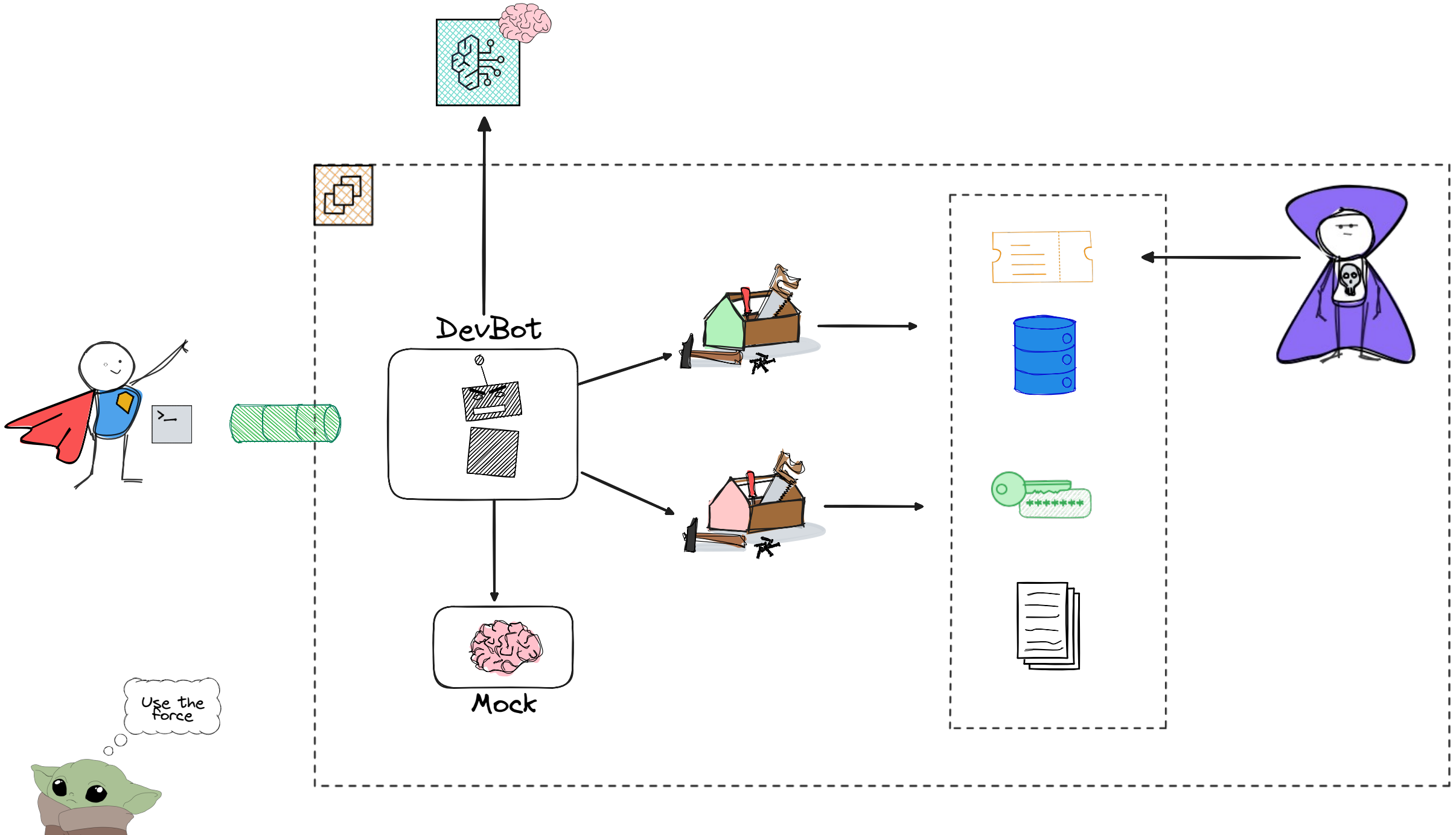
Meta's Rule of Two



All 3?
Human approves every action

Fewer tools | Least privilege | Policy in code | Human approval | Circuit breakers | Log every call

Hands On


DevBot
Mock
Use the force

Q&A

11110000 10011111 10011011 10010001
00100000 01010011 01111001 01110011
01110100 01100101 01101101 00100000
01001110 01101111 01110100 01100101 00111010
00100000 01000011 01110101 01110010
01101001 01101111 01110011 01101001 01110100
01111001 00100000 01000100 01100101
01110100 01100101 01100011 01110100 01100101
01100100 00101110





It's not a job it's a passion